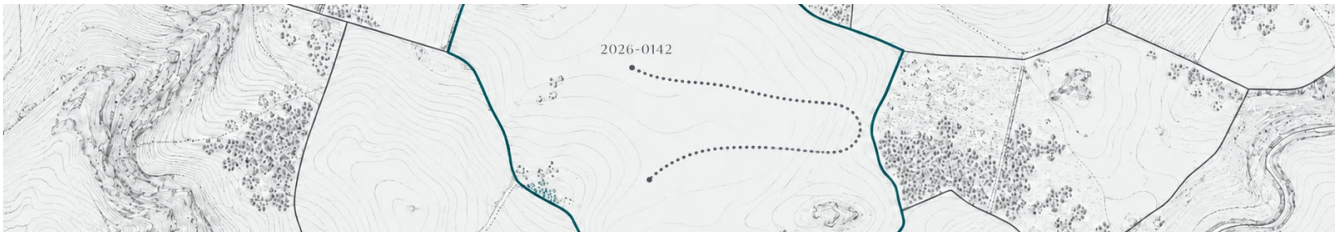
Identity for AI agents



Delegated access, revocation and audit for an AI agent in government.

Michael Owen Meijer, Oomny B.V. · identity architect and AI engineer for government and cloud

The problem

AI agents are getting access to case files, mailboxes and line-of-business systems. Often with the user's own token, a shared API secret or a broadly privileged service account. A manipulated agent can then do whatever that identity can, and the logs of that system cannot tell whether the human or the agent acted.

The approach

An agent is treated as seriously as an employee when it comes to identity:

- **Its own identity.** The agent is a client of its own, with a key instead of a shared secret. In the Entra variant: an agent identity with a sponsor, secretless through a managed identity.
- **A mandate per task.** The employee consents to one agent and one task. For every action the agent gets a token with only the rights for that one tool, valid for 60 seconds, usable once and bound to its key (OAuth 2.0 Token Exchange, DPoP).
- **Never more than the human.** The API only allows what the agent, the employee and the task all permit. An agent never records a formal decision.
- **Revocable.** The employee revokes the mandate and the next action fails, including with tokens fetched in advance. The administrator has a kill switch.
- **Audit trail.** Every decision the API makes on a tool action or a mandate is recorded in a hash chain with a separate anchor: who, on whose behalf, which tool, which case, which token, and why. Refused token requests are in the Keycloak events.

The evidence

A public repository with a working demo in one command (`make demo`). A LangGraph agent works over MCP on the case API of a fictional municipality. In the second scenario the demo simulates an agent that follows an instruction injected into a case file, and the boundary holds: Keycloak refuses the token for a decision, and the API refuses the case outside the mandate.

55 integration tests against the real stack. A threat model against the OWASP Top 10 for Agentic Applications 2026 and the OWASP Non-Human Identities Top 10, with the test behind each control. An honest section on what this does not solve.

Keycloak 26.8 (open source) and Microsoft Entra Agent ID side by side, with Terraform for Entra (checked with terraform validate and mocked tests, not deployed to a tenant).

Why me

Identity and security since 2011, nearly eight years for the four largest Dutch municipalities: federation, Keycloak, Entra ID, and the move from personal access tokens to managed identities. Since 2026 I have been building AI agents with tool calling and MCP. That intersection is exactly where public organisations are now: admitting agents without losing control over access.

Repo: github.com/oomny-nl/agent-mandaat · **Site:** www.oomny.nl · **Mail:** michael@oomny.nl